CLOUD-SECURITY-ASSURANCE

클라우드 도입 보안·아웃소싱·CSAP

연관 기출 · 128-2-2, 129-4-6, 130-4-3, 134-2-1, 130-3-6

한눈에 이해

사업자가 받은 인증과 이용자가 안전하게 설정·운영하는 일은 구분하여, 계약에 서 종료와 복구까지 확인합니다.

정의와 핵심 원리

클라우드보안은공유책임 환경에 서 데이터·신원·워크로드·관리면·연결망을보호하고 제공자 위험을 관리하는 활동입니다. 공공부문 이용은 CSAP등해당제도와 보안성 검토·데이터등급·서비스 계약을 함께 검토해야합니다.

• 사전단계는 업무·정보등급·법적이용 근거·위험을 분석하고 서비스 모델·배치·데이터위치·운영 책임을 결정합니다. 설계는 망연결·인증·암호 키·로그·백업·관리자접속·취약점·사고통지·공급망을포괄합니다. 구축뒤구성검증·이관·복구·부하시험으로 전환을판단합니다.

• 아웃소싱계약에 는 보호 목표·접근 권한·하도급·사고 대응·감사권·가용성 측정·복구·데이터 반환·삭제 증빙·계약 종료를 명시합니다. 제공자 장애와 사업중단·가격·종속·국외이전위험도 관리합니다. 암호화시제공자 권한과 키 소유·회전·복구 경로를 따로확인합니다.

• CSAP는 적용 서비스·범위·인증 상태를 확인해야 하며 IaaS인증이 그위의모든 SaaS까지자동인증하는 것은아닙니다. 공공이용4가 지구조, 유형별평가 항목·점수·절차, 공공SaaS가 이드및금융SLA의 세부의무는 최신 원문을 읽기전확정하지 않습니다.

구조·비교·판단

구분	핵심 원리	적용·한계
제공자보안	시설·서비스 기반 보호	인증 범위·책임 확인
이용자보안	데이터·권한·설정·업무	서비스 모델별경계
보증·계약	측정·감사·사고·종료	통제 실효성·증빙

적용 예제

공공 SaaS 전환 검토

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 민감업무 정보를 처리하는문서협업서비스 가정

1. 처리 정보와 외부 연계·국외저장여부를분류합니다.
2. 인증서의 서비스명·범위·유효상태와 별도 보안검토 요구를 확인합니다.
3. 관리 권한·로그반출·백업 복원·계약 종료시표준형식반환을실제 시험합니다.
4. 잔여위험과 예외를 업무 책임자가 승인하고 재평가 주기를 둡니다.

결과·해석: 기술 검토와 공급자·계약·철수위험을 한목록으로 추적합니다.

전제·주의: 이번조사는제도세부원문을 충분히확보하지못했습니다.일반 설계예시를법정인증 요건충족으로 사용하면 안됩니다.

답안 골격과 혼동 방지

도입수명 주기 → 공유책임도 → 보안요소 → CSP실사·계약 → CSAP 확인 범위

- 제공자보안인증을 이용자준수전체로간주하지 않습니다.
- 계약 종료·삭제 증빙을누락하지 않습니다.

내용을 가리고 회상

1. 서비스 모델이 바뀌면책임은 어떻게달라집니까?
2. 관리면·데이터면보호를 왜분리합니까?
3. 반환·삭제 시험을 언제합니까?

적용 기준과 근거

일반 보안원리는 설명했으나CSAP 평가 기준·공공SaaS·금융SLA가 이드전문 미열람.해당소요구는 확인필요로유지.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-145: Definition of Cloud Computing - Peter Mell; Timothy Grance / NIST; 2011-09; 확인 2026-11-05.
- ISMS-P 공식 누리집 - KISA; 2026 표시 페이지; 확인 2026-11-05.